

UNIT IV: USER AUTHENTICATION (5 HRS)

- 4.1. User Authentication principles
- 4.2. Password-Based Authentication
- 4.3. Token-Based Authentication
- 4.4. Biometric Authentication
- 4.5. Remote User Authentication
- 4.6. Two Factor Authentication

WHAT IS USER AUTHENTICATION?

- **User authentication** is the process by which a system **confirms that a user is really who they claim to be**.
- It is the **first line of defense** in computer security where it forms the **foundation of access control** and the basis for **user accountability** (tracking who did what).
- **Two Main Functions of User Authentication: Identification and Verification**

1) Identification (Claiming identity)

- The user identifies herself to the system by presenting a credential, such as user ID.
- Example: Alice Toklas uses the user ID: **ABTOKLAS**
- This ID is **not secret** and is stored in the system
- Allows others to send her emails, etc.

2) Verification (Proving identity)

- The system asks to -“Prove that you are really Alice.”
- Alice proves this by providing **authentication information**, such as: Password, PIN, Fingerprint, Smart card, OTP, etc.
- This information **must be secret**.

Example:

Alice enters her password, known only to her and the system.

USER AUTHENTICATION PRINCIPLE

- It helps build trust by verifying the identity of a specific user or system. Authentication ensures that only authorized users can access a system, preventing unauthorized access that could lead to system damage, data theft, or other security issues.

User Authentication Methods:

- **Knowledge Factors:** These involve information that the user must know to log in and access the system, such as usernames, passwords, IDs, and PINs (Personal Identification Numbers).
- **Possession Factors:** These include items that the user must physically possess to gain access, such as OTPs (One-Time Passwords), employee ID cards, or smartphone-based authentication apps.
- **Inherence Factors:** These are based on the user's inherent physical or behavioral traits used to verify identity, such as biometrics including fingerprint scans, retina or iris scans, facial recognition, and voice authentication.

PASSWORD-BASED AUTHENTICATION

Password based authentication is the process of gaining access to resources to which one is entitled with the help of set of credentials containing a username and password.

- Password based authentication is the most preferred methodology for the majority of resources in organization requiring a username and password.
- The password-based authentication method gets its fondness for its simplicity, cost-effectiveness, ease of operability and practicality

TYPES OF PASSWORD BASED AUTHENTICATION

- a) Store password in plain text:** Store password in plain text and used the password for authentication purpose
- b) Derived from password:** In this type, the server first encrypt the password before storing to the database and uses the same encryption algorithm to compare the password and if matched, then only the users will be authenticated
- c) Message digest password:** In this type, the message digest is used to create a digest of password and store in the database, and compare the hash using same hashing function to compare if the authentication should be granted or not.

WHY PASSWORDS ARE VULNERABLE

- Passwords are the most common authentication method but are easy to attack.

Main Attack Types

- **Offline dictionary attack** – Attacker steals the password file and compares hashes with common passwords.
- **Specific account attack** – Guessing passwords for one user repeatedly.
- **Popular password attack** – Trying common passwords across many accounts.
- **Password guessing** – Using personal info of the user.
- **Workstation hijacking** – Using a logged-in unattended computer.
- **User mistakes & social engineering** – Writing down or sharing passwords.
- **Password reuse** – Same password used on multiple systems.
- **Network eavesdropping** – Capturing passwords sent over a network.

WHY PASSWORDS ARE STILL USED

- Hardware methods (fingerprint, smart cards) are costly.
- Tokens are inconvenient.
- Single sign-on creates a single point of failure.
- Password managers have usability issues.

Studies show:

- Many passwords give only **10–20 bits of security**.
- 25% of passwords can be guessed in under an hour.

Password Cracking Methods

- **Dictionary + variations** -Attackers start with a **list of common words/passwords** (like password, admin, names, cities) then, they try small changes.
- **Rainbow tables** :Attackers **precompute hashes** for millions of common passwords and store them in a big table. If they steal a password hash, they just **look it up** in the table instead of guessing each time.
- **GPU-based brute force** (billions of guesses/sec).
- **Using leaked real passwords** to model common patterns.

Password Selection Strategies

- Goal: Make passwords **hard to guess but easy to remember**.
- **Methods**
 - **User education** – Often ignored.
 - **Computer-generated passwords** – Hard to remember.
 - **Reactive checking** – System cracks weak passwords later.
 - **Proactive checking (best)** – System rejects weak passwords during creation.

Password Policies (NIST)

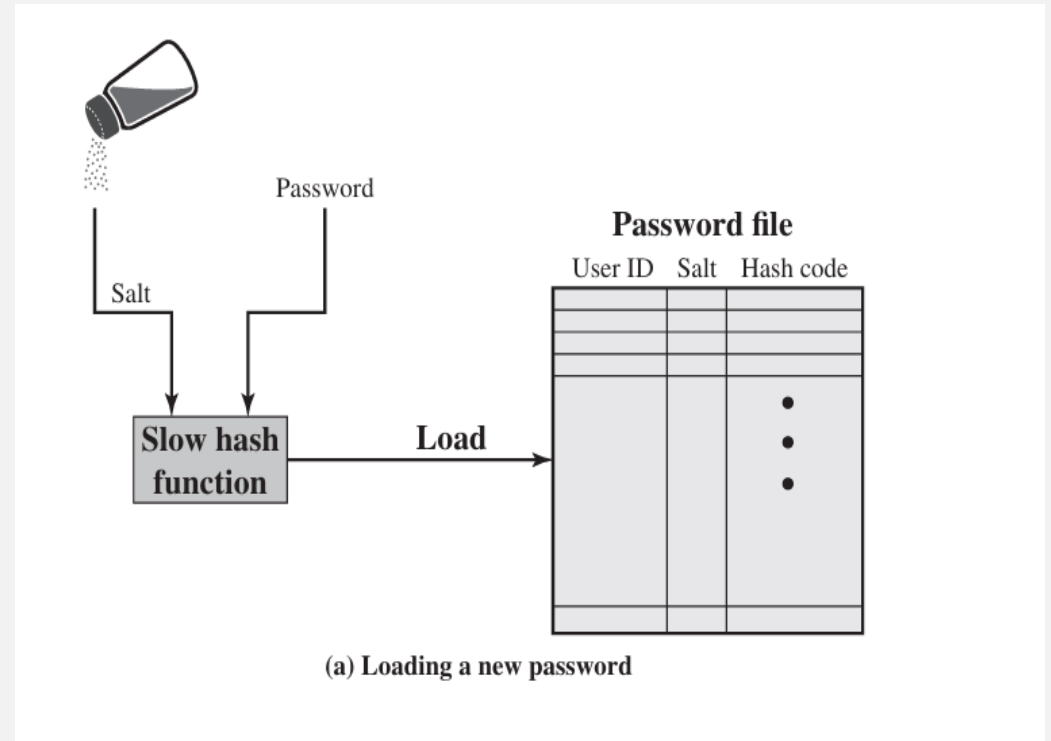
- Two good rules:
 - **basic16**: At least 16 characters.
 - **comprehensive8**: 8 chars + upper/lowercase + symbol + digit.
 - Research shows **basic16 is stronger and easier**.

HASHED PASSWORDS AND SALT (UNIX METHOD)

- Instead of storing passwords directly:
- System stores **hash(password + salt)**.
- **Salt** is a pseudo-random value stored with the hash.

Purpose of Salt

- Prevents identical passwords from looking the same.
- Makes dictionary attacks much harder.
- Prevents detecting same password across systems.



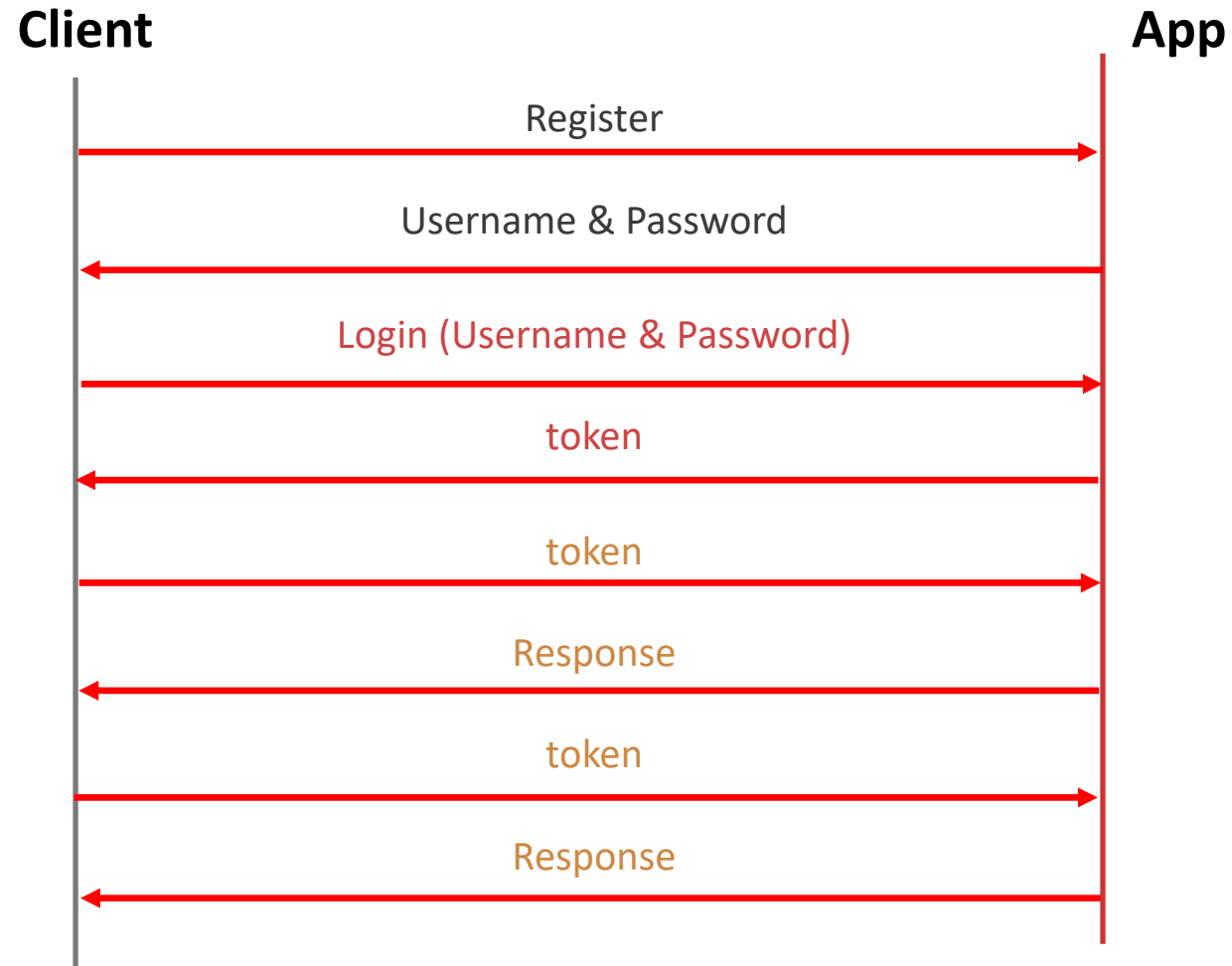
BLOOM FILTER FOR PASSWORD CHECKING

- Instead of storing huge bad-password lists, use a **Bloom filter**.
- Very fast and memory-efficient way to reject common passwords.
- May reject some good passwords (false positives), but improves security.

TOKEN BASED AUTHENTICATION

- Token-based authentication is a protocol that allows users to verify their identity and receive a unique access token in return.
- Once issued, this token lets users access a website or application without repeatedly entering their login credentials each time they return to the same system. Access is maintained as long as the token remains valid, and it is invalidated when the user logs out or exits the application.
- This method adds an extra layer of security, and it also enables administrators to have better control and monitoring over user actions and transactions.
- However, implementing token-based authentication can be complex, as developers need to carefully consider various edge cases during development.
- JWT (JSON Web Token) is a common example of token-based authentication.

Token Based Authentication



TOKEN AUTHENTICATION TYPES

I. Connected Authentication

- This means the authentication device is **physically attached** to the system when you log in.

How it works:

- You plug or insert something into the computer or device
- The system reads it directly

Examples:

- Smart card inserted into a card reader
- USB security key (like a login dongle)

TOKEN AUTHENTICATION TYPES

2. Contactless Authentication

- This means the device does not touch the system but works using **short-range wireless communication**.

How it works:

- You just bring the device close
- It communicates automatically

Examples:

- NFC debit/credit cards (tap to pay)
- RFID access cards for office entry
- Smart devices like wearable authentication rings or watches

Simple idea: “I just tap or come close no physical connection needed.”

TOKEN AUTHENTICATION TYPES

3. Disconnected Authentication

- This means the authentication happens **without physical contact or proximity**, usually over a network.

How it works:

- System sends a request
- You verify from another device (often remote)
- Communication happens over the internet or mobile network

Examples:

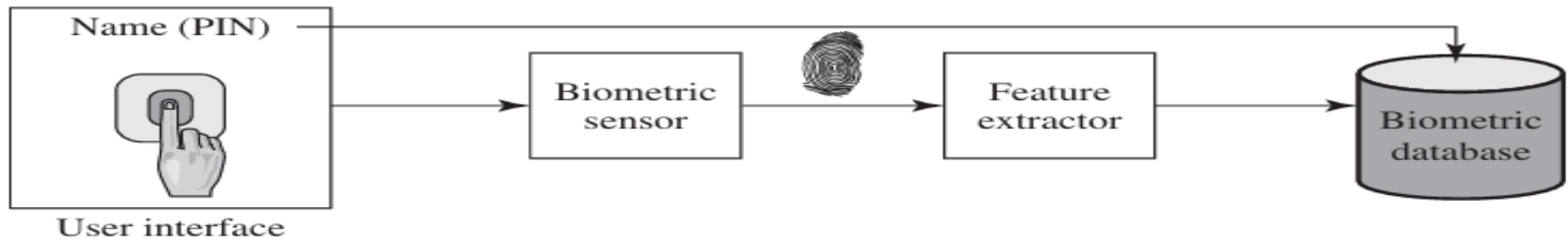
- OTP sent to your phone/email
- Google Authenticator app codes
- Two-factor authentication (2FA)

WORKING OF TOKEN BASED AUTHENTICATION

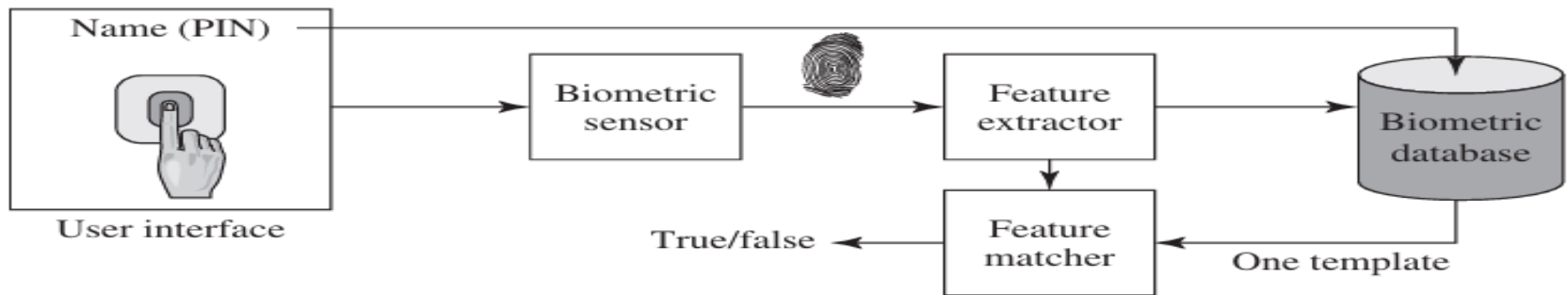
- In token-based authentication, a user initiates a request to access a server or application, typically by providing login credentials such as a password or another authentication method.
- The server processes this request and verifies the user's identity by validating the submitted credentials.
- Once the user is successfully authenticated, the server may interact with an authentication device (like a phone or security key) and then generates a token, which is sent to the user.
- The issued token is stored on the user's side, usually in the browser, and is used to authorize future requests during the active session.

BIOMETRIC AUTHENTICATION

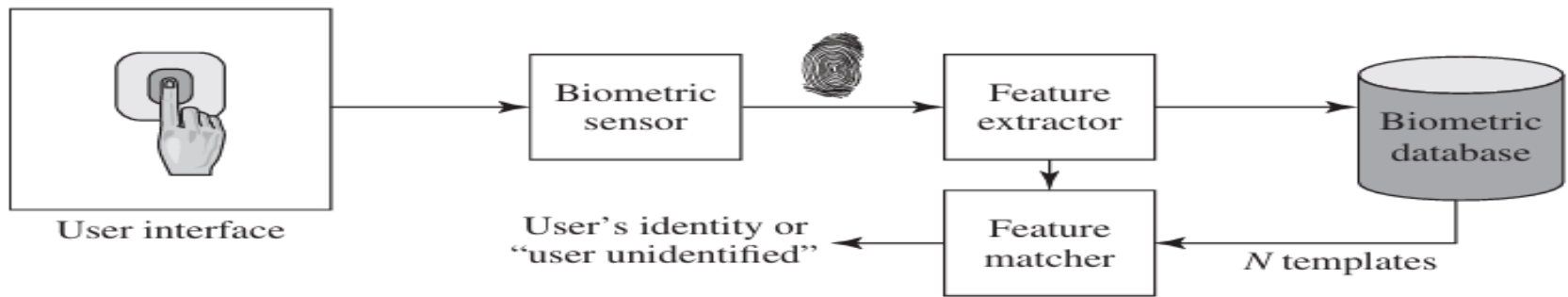
- Biometric authentication refers to the security procedure that involves the use of unique biological characteristics of individuals such as retinas, voices, facial characteristics and fingerprints in order to verify people who they claim to be.
- This process is used to control access to physical and digital resources, such as buildings, rooms and different devices.



(a) Enrollment



(b) Verification



(c) Identification

TYPES OF BIOMETRIC AUTHENTICATION

Type	What is measured	Notes
Fingerprint	Ridges & minutiae on fingertip	Very common, good accuracy, cheap sensors
Face	Geometry of eyes, nose, lips, chin; sometimes IR thermogram	Convenient, contactless, affected by lighting/pose
Iris	Detailed iris texture	Very high accuracy, requires close capture
Retina	Blood vessel pattern at back of eye	Very accurate, intrusive capture
Hand geometry	Finger lengths, widths, hand shape	Fast, lower accuracy
Voice	Vocal tract characteristics	Affected by noise/illness
Signature	Writing dynamics & style	Behavioral; varies over time

CRITERIA FOR SELECTION OF BIOMETRIC

- **Universality:** Each person should possess the biometric traits which is being used. For e.g. facial recognitions
- **Uniqueness:** No two persons must be same in terms of biometric traits being used. i.e. everyone must be unique in terms of biometric terms used.
- **Permanence:** It should be invariant over time. I.e it should changed over time
- **Collectability:** Biometric traits must be easily measurable
- **Performance:** Processing of biometric must be easy and fast
- **Secure:** It must be secure and can't be copied
- **Acceptability:** People should be willing to accept the biometric system

ADVANTAGES OF BIOMETRIC USER AUTHENTICATION

- **High security and accuracy**
Biometric traits are **unique to each person**, making it very hard for attackers to copy or guess them.
- **Cannot be forgotten or lost**
Unlike passwords or smart cards, you **always carry your biometrics** with you.
- **Difficult to share or steal**
You can share a password, but you **cannot share your fingerprint or iris** easily.
- **Convenience and speed**
Authentication is fast—just a touch, look, or voice command. No need to remember complex passwords.
- **Non-repudiation (strong proof of identity)**
Since biometrics are tied to a specific person, users **cannot deny** performing an action after authentication.
- **Reduces password management problems**
No password resets, no weak passwords, and no password reuse issues.

REMOTE USER AUTHENTICATION

- **Remote user authentication** happens when a user proves their identity to a system **over a network** (Internet, LAN, telecom link), not on a local machine like an ATM or office PC.
- Because communication travels over a network, it faces extra threats:
 - i. Eavesdropping (someone listening)
 - ii. Replay attacks (reusing captured messages)
 - iii. Device spoofing (fake client/capture device)
 - iv. Password/passcode theft in transit
- To defend against this, systems use a **challenge–response protocol** with a **nonce** (random number used once).

WHAT IS A CHALLENGE-RESPONSE PROTOCOL?

- User sends **ID** to host.
- Host sends a **challenge** → random number r (nonce) and functions to use.
- User computes a response using their secret (password/token/biometric) + r .
- Host verifies the response using stored data.
- Because r changes every time, **old captured messages cannot be reused** (prevents replay attack).

REMOTE AUTHENTICATION METHODS

- **Password** – User sends a response made from the password hash + random number. Password is never sent.
- **Token (OTP/smart card)** – Token generates a passcode; response uses passcode + random number.
- **Static biometric** – Fingerprint/iris is captured; encrypted template + random number sent.
- **Dynamic biometric** – User speaks/types a random sequence; biometric signal + random number sent.
- **Common idea:** All use a **random challenge (nonce)** to stop replay attacks.

TWO-FACTOR AUTHENTICATION (2FA)

- **Two-Factor Authentication (2FA)** is a login method that requires **two different categories of evidence** to prove a user's identity.
- **The Three Authentication Factors**
- **Something you know** – password, PIN
- **Something you have** – phone, OTP token, smart card
- **Something you are** – fingerprint, face, iris
- **2FA = any two of the above used together**

HOW 2FA WORKS

1. User enters **username + password** (knowledge factor).
2. System asks for a **second factor**.
3. User provides:
 - OTP from phone/token **or**
 - Biometric scan **or**
 - Smart card insertion.
4. System verifies **both** before granting access.

WHY 2FA IS MORE SECURE

- If a password is guessed or stolen, attacker **still needs** the second factor.
- Protects against:
 - Password guessing
 - Keylogging
 - Shoulder surfing
 - Replay attacks
 - Token theft (when combined with PIN)

Common 2FA Combinations

First Factor	Second Factor	Example
Password	OTP from phone	Logging into email/bank
ATM card	PIN	ATM withdrawal
Password	Fingerprint	Mobile phone unlock
Smart card	PIN	Office access control

ADVANTAGES AND DISADVANTAGES OF 2-FACTOR AUTHENTICATION

Advantages

- Much stronger than single password login
- Simple to use
- Low cost (OTP apps, SMS, biometrics)
- Widely used in banking, email, cloud services

Limitations

- Slightly slower login process
- Requires carrying a device (phone/token)
- SMS OTP can be vulnerable to SIM swap (better to use authenticator apps)

